**MF0487_3 · AUDITORÍA DE SEGURIDAD INFORMÁTICA**

# LABORATORIO 2

## Análisis de Vulnerabilidades con OpenVAS

### Objetivo: Metasploitable 2

Entorno: 2 máquinas — Kali Linux Purple (auditora) + Metasploitable 2 (objetivo)
Herramientas: OpenVAS/GVM (nativo Kali) · Nmap NSE · Nikto
Normativa: MAGERIT v3 · ENS (op.pl.3) · ISO 27001:2022 A.8.8 · RGPD art. 32
Duración estimada: 4 horas · Nivel: Intermedio · Prerrequisito: LAB-01

⚠ **Este documento es de uso exclusivo en entornos de laboratorio controlado.**

# 0. FICHA TÉCNICA DEL LABORATORIO

| | | | |
|---|---|---|---|
| **Código** | LAB-02 | **UDs** | UD3, UD4, UD6 |
| **Título** | Análisis de Vulnerabilidades con OpenVAS — Metasploitable 2 | **Duración** | 4 h |
| **Normativa** | MAGERIT v3 · ENS (op.pl.3) · ISO 27001:2022 A.8.8 · RGPD art. 32 | **Nivel** | Intermedio |
| **Herramientas** | OpenVAS/GVM (Kali nativo) · Nmap NSE · Nikto | **Prerrequisito** | LAB-01 |
| **Máquinas** | *Kali Linux Purple (auditora) — IP según entorno de red del aula \| Metasploitable 2 (objetivo) — IP según entorno de red del aula* | | |
| **Objetivo** | *Realizar un análisis de vulnerabilidades completo sobre Metasploitable 2 usando OpenVAS/GVM instalado de forma nativa en Kali Linux Purple. Clasificar los hallazgos según CVSS v3.1, relacionarlos con el marco MAGERIT v3 y ENS, y elaborar el borrador del informe técnico de auditoría.* | | |

# 1. MARCO NORMATIVO

El análisis de vulnerabilidades tiene un sólido respaldo normativo en el contexto español y europeo. No es una actividad opcional, sino un requisito explícito de las principales referencias aplicables:

## 1.1 Fundamento normativo

- ENS — RD 311/2022, medida op.pl.3 (Gestión de la configuración de seguridad): los sistemas de categoría MEDIA y ALTA deben realizar análisis de vulnerabilidades periódicos y documentar los resultados. La corrección de vulnerabilidades críticas debe producirse en un plazo máximo de 7 días.
- ISO 27001:2022, control A.8.8 (Gestión de vulnerabilidades técnicas): exige obtener información oportuna sobre vulnerabilidades técnicas, evaluar la exposición de la organización y tomar medidas adecuadas. La evidencia de estas actividades es requisito de la certificación.
- RGPD art. 32.1.d: requiere 'un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas'. El análisis de vulnerabilidades es el mecanismo técnico habitual para cumplir este mandato.
- MAGERIT v3 — Libro I, cap. 5: la identificación de vulnerabilidades es parte de la caracterización de amenazas, paso necesario para calcular la degradación y la probabilidad de materialización del riesgo.
- CCN-STIC 817 (Gestión de ciberincidentes, 2023): establece el ciclo de gestión de vulnerabilidades en el ámbito del ENS, incluyendo la obligatoriedad de priorizar y documentar los hallazgos según su severidad CVSS.

## 1.2 CVSS v3.1 — Escala de severidad

El Common Vulnerability Scoring System v3.1 es el estándar de referencia para medir la severidad. Es el sistema usado por el NVD (NIST), el CCN-CERT y OpenVAS.

| Puntuación CVSS v3.1 | Severidad | Plazo de corrección (ENS) | Acción requerida |
|---|---|---|---|
| 9.0 – 10.0 | Crítico | ≤ 7 días | Corrección inmediata. Escalar a dirección. |
| 7.0 – 8.9 | Alto | ≤ 30 días | Plan de corrección urgente. Monitorizar activamente. |
| 4.0 – 6.9 | Medio | ≤ 90 días | Incluir en ciclo de parcheo planificado. |
| 0.1 – 3.9 | Bajo | Plan de mejora | Evaluar coste/beneficio de corrección. |
| 0.0 | Informativo | Sin plazo fijo | Documentar. Considerar en auditorías futuras. |

## 1.3 Tipos de análisis: caja negra vs. caja gris

En este laboratorio se realizarán dos tipos de análisis sobre el mismo objetivo, reproduciendo las dos perspectivas habituales en una auditoría real:

| Tipo | Credenciales | Qué detecta | Cuándo se usa |
|---|---|---|---|
| Caja negra | Sin credenciales | Vulnerabilidades visibles desde red, servicios expuestos, versiones | Auditoría externa. Simula un atacante sin acceso previo. |
| Caja gris | Con credenciales SSH | Vulnerabilidades del SO, paquetes obsoletos, configuraciones internas | Auditoría interna. Simula un empleado o sistema comprometido. |

⚠ **AVISO:** Todo análisis de vulnerabilidades debe realizarse sobre sistemas propios o con autorización escrita. El acceso no autorizado a sistemas informáticos es un delito tipificado en el art. 197 bis del Código Penal (penas de hasta 2 años). Este laboratorio opera en un entorno aislado y controlado.

# 2. ENTORNO DE LABORATORIO

## 2.1 Topología — Dos máquinas

El laboratorio opera con únicamente dos máquinas físicas o virtuales en la misma red. No se requiere ningún servicio Docker ni infraestructura adicional.

| Máquina | Rol | Sistema operativo | Servicios relevantes para el lab |
|---|---|---|---|
| Kali Linux Purple | Auditora (atacante controlado) | Kali Rolling (2023.x o superior) | OpenVAS/GVM, Nmap, Nikto, Wireshark |
| Metasploitable 2 | Objetivo único del análisis | Ubuntu 8.04 LTS (vulnerable) | FTP, SSH, Telnet, HTTP, SMB, MySQL, PostgreSQL, IRC, NFS... |

ℹ Las IPs concretas dependen de la configuración de red del aula. Anota aquí las IPs asignadas antes de comenzar: Kali: _____ | Metasploitable 2: _____

## 2.2 Verificación previa del entorno

Antes de iniciar cualquier tarea, ejecuta desde Kali las siguientes comprobaciones:

```
# Confirmar IP propia de Kali
ip addr show | grep 'inet ' | grep -v 127

# Confirmar conectividad con Metasploitable 2
ping -c 3 <IP_METASPLOITABLE>

# Verificar que OpenVAS está instalado y el servicio activo
gvm-check-setup 2>&1 | tail -5

# Si el servicio no está corriendo, iniciarlo:
sudo gvm-start
```

✓ **TIP:** gvm-start puede tardar entre 2 y 4 minutos en estar completamente operativo. Espera hasta que la línea 'Greenbone Security Assistant is running' aparezca en el terminal antes de abrir el navegador.

## 2.3 Instalación de OpenVAS en Kali Linux Purple

OpenVAS/GVM está disponible en los repositorios oficiales de Kali. Si no está instalado en el equipo del aula, ejecuta el siguiente procedimiento una única vez:

```
sudo apt update && sudo apt install -y gvm

# Configuración inicial (descarga feeds de vulnerabilidades ~15-20 min)
sudo gvm-setup

# Comprueba que todo es correcto
sudo gvm-check-setup

# Anota la contraseña generada para el usuario admin
# (se muestra al final de gvm-setup — guárdala antes de continuar)
```

> ⚠ **AVISO:** gvm-setup descarga las bases de datos de vulnerabilidades (NVT feed, SCAP, CERT). Este proceso requiere conexión a Internet y unos 15-20 minutos. Realizarlo antes del laboratorio, no durante. Si el aula no tiene Internet, el instructor debe pre-instalar el equipo con el feed ya descargado.

## 2.4 Credenciales de Metasploitable 2

Para el escaneo autenticado (caja gris) necesitarás las credenciales SSH por defecto de Metasploitable 2:

| Servicio | Usuario | Contraseña | Uso en el laboratorio |
|---|---|---|---|
| SSH | msfadmin | msfadmin | Credencial para escaneo autenticado OpenVAS (caja gris) |
| MySQL | root | (vacía — sin contraseña) | Verificación manual — Tarea 4 |
| PostgreSQL | postgres | postgres | Verificación manual — Tarea 4 |
| Tomcat Manager | admin | admin | Verificación manual — Tarea 4 |
| FTP | anonymous | (cualquier valor) | Verificación acceso anónimo — Tarea 4 |

> ⚠ **AVISO:** Estas credenciales son exclusivas del entorno Metasploitable 2 de laboratorio. No son válidas ni deben usarse en ningún sistema real.

# 3. OBJETIVOS DE APRENDIZAJE

- Instalar y configurar OpenVAS/GVM de forma nativa en Kali Linux Purple.
- Ejecutar un análisis de vulnerabilidades sin credenciales (caja negra) sobre Metasploitable 2.
- Ejecutar un análisis autenticado con credenciales SSH (caja gris) y comparar los resultados con el escaneo anterior.
- Verificar manualmente los hallazgos más críticos con Nmap NSE y Nikto, diferenciando verdaderos positivos de falsos positivos.
- Clasificar los hallazgos según CVSS v3.1 y relacionarlos con el catálogo de amenazas de MAGERIT v3.
- Elaborar el borrador del informe técnico de vulnerabilidades conforme a ENS (op.pl.3) e ISO 27001:2022 A.8.8.
- Construir el plan de remediación priorizado con plazos ENS.

# 4. DESARROLLO DEL LABORATORIO

## TAREA 1 — Configuración de OpenVAS y primer escaneo sin credenciales (60 min)

### 1.1 Acceso a la interfaz web GSA

Greenbone Security Assistant (GSA) es la interfaz web de OpenVAS/GVM. Ábrela desde el navegador de Kali:

```
sudo gvm-start
firefox https://127.0.0.1:9392
```

Acepta el certificado autofirmado (Add Exception en Firefox). Inicia sesión con usuario admin y la contraseña generada durante gvm-setup.

> ℹ Si no recuerdas la contraseña del admin, puedes restablecerla con: sudo runuser -u _gvm -- gvmd --user=admin --new-password=NuevaPass123

### 1.2 Actualización del feed de vulnerabilidades

Antes del primer escaneo, comprueba que el feed NVT está actualizado. Ve a Administration → Feed Status. Los tres feeds (NVT, SCAP Data, CERT Data) deben mostrar Current o una fecha reciente.

Si alguno está desactualizado, actualiza desde terminal:

```
sudo runuser -u _gvm -- greenbone-nvt-sync
sudo runuser -u _gvm -- greenbone-scapdata-sync
sudo runuser -u _gvm -- greenbone-certdata-sync
```

### 1.3 Crear el Target (objetivo)

El Target define la máquina a analizar. Ve a Configuration → Targets → icono ★ (New Target):

1. Name: Metasploitable2-SinCredenciales
2. Hosts: introduce la IP de Metasploitable 2
3. Port List: selecciona All IANA assigned TCP and UDP
4. Alive Test: ICMP, TCP-ACK Service & ARP Ping
5. SSH Credentials: dejar vacío (escaneo sin credenciales)
6. Haz clic en Save.

### 1.4 Crear y lanzar la tarea de escaneo

Ve a Scans → Tasks → icono ★ (New Task):

7. Name: LAB02-Metasploitable2-SinCredenciales
8. Scan Targets: selecciona Metasploitable2-SinCredenciales
9. Scanner: OpenVAS Default
10. Scan Config: Full and fast
11. Haz clic en Save.
12. En la lista de tareas, haz clic en el botón ► (Start) de la tarea creada.

> ✓ **TIP:** El escaneo Full and fast tardará entre 20 y 40 minutos. Mientras esperas, avanza con la Tarea 2 (configurar el escaneo autenticado) y vuelve a revisar los resultados cuando finalice.

### 1.5 Seguimiento del progreso

Puedes ver el progreso en Scans → Tasks. La columna Status mostrará el porcentaje completado. Cuando llegue al 100% y Status cambie a Done, el escaneo ha finalizado.

Alternativamente, desde terminal:

```
sudo tail -f /var/log/gvm/gvmd.log | grep -E 'progress|done|error'
```

# TAREA 2 — Escaneo autenticado con credenciales SSH (45 min)

Un escaneo autenticado permite a OpenVAS conectarse al sistema objetivo como usuario legítimo y examinar el interior del sistema: paquetes instalados, versiones del kernel, configuraciones de servicios, usuarios del sistema. Detecta vulnerabilidades internas que son invisibles desde el exterior.

## 2.1 Crear las credenciales SSH

Ve a Configuration → Credentials → icono ★ (New Credential):

13. Name: SSH-msfadmin
14. Type: Username + Password
15. Username: msfadmin
16. Password: msfadmin
17. Haz clic en Save.

## 2.2 Crear el Target autenticado

Ve a Configuration → Targets → icono ★ (New Target):

18. Name: Metasploitable2-ConCredenciales
19. Hosts: IP de Metasploitable 2 (la misma)
20. Port List: All IANA assigned TCP and UDP
21. SSH Credentials: selecciona SSH-msfadmin
22. SSH Port: 22
23. Haz clic en Save.

## 2.3 Crear y lanzar la tarea autenticada

Ve a Scans → Tasks → icono ★ (New Task):

24. Name: LAB02-Metasploitable2-ConCredenciales
25. Scan Targets: selecciona Metasploitable2-ConCredenciales
26. Scanner: OpenVAS Default
27. Scan Config: Full and fast ultimate (más exhaustivo para entorno controlado)
28. Haz clic en Save y lanza con ▶

> ℹ Full and fast ultimate activa checks adicionales que podrían afectar la disponibilidad del servicio en sistemas reales. En un entorno de laboratorio con Metasploitable 2 es aceptable. En auditorías reales de producción se usaría Full and fast o una política personalizada acordada con el cliente.

## 2.4 Verificar que la autenticación SSH fue exitosa

Una vez finalizado el escaneo autenticado, en el informe de resultados busca en la parte superior la sección Authentication. Debe aparecer:

- SSH Login: Successful

Si aparece SSH Login: Failed, la credencial no funcionó y los resultados serán equivalentes al escaneo sin credenciales. En ese caso, verifica que el servicio SSH de Metasploitable 2 está activo:

```
nmap -p 22 <IP_METASPLOITABLE>
ssh msfadmin@<IP_METASPLOITABLE>   # para confirmar acceso manual
```

# TAREA 3 — Análisis y exportación de resultados (30 min)

## 3.1 Resumen comparativo de resultados

Una vez finalizados ambos escaneos, completa la siguiente tabla de comparación. Los datos se obtienen desde Scans → Reports, seleccionando cada informe:

| Métrica | Escaneo SIN credenciales | Escaneo CON credenciales SSH |
|---|---|---|
| Total vulnerabilidades encontradas | _____ | _____ |
| Críticas (CVSS ≥ 9.0) | _____ | _____ |
| Altas (CVSS 7.0 – 8.9) | _____ | _____ |
| Medias (CVSS 4.0 – 6.9) | _____ | _____ |
| Bajas / Informativas | _____ | _____ |
| ¿Autenticación SSH exitosa? | N/A | Sí / No |
| Vulnerabilidades exclusivas de este escaneo | — | _____ |

La diferencia entre ambas columnas refleja la 'superficie de ataque interna': vulnerabilidades que solo un actor con acceso al sistema (empleado, proceso comprometido) podría explotar. Esta distinción es relevante para el análisis de riesgos MAGERIT v3 (probabilidad de explotación).

## 3.2 Exportación de informes

Exporta los resultados en los formatos necesarios para el informe de auditoría:

29. Ve a Scans → Reports y selecciona el informe del escaneo sin credenciales.
30. Haz clic en el botón de descarga (icono nube) y selecciona XML. Guarda como: lab02_openvas_sin_cred.xml
31. Descarga también en formato PDF: lab02_openvas_sin_cred.pdf
32. Repite para el escaneo con credenciales: lab02_openvas_con_cred.xml y lab02_openvas_con_cred.pdf

```
# Crea el directorio de trabajo del laboratorio
mkdir -p ~/lab02 && mv ~/Downloads/lab02_openvas_*.* ~/lab02/
```

## 3.3 Identificar los 10 hallazgos más críticos

En el informe del escaneo con credenciales, ordena los resultados por severidad (columna Severity, de mayor a menor). Anota los 10 primeros:

| # | Nombre de la vulnerabilidad | Puerto | CVSS v3.1 | Herramienta de verificación |
|---|---|---|---|---|
| 01 | _____ | _____ | _____ | Nmap NSE / Nikto |
| 02 | _____ | _____ | _____ | Nmap NSE / Nikto |
| 03 | _____ | _____ | _____ | Nmap NSE / Nikto |
| 04 | _____ | _____ | _____ | Nmap NSE |
| 05 | _____ | _____ | _____ | Nmap NSE |
| 06 | _____ | _____ | _____ | Manual |
| 07 | _____ | _____ | _____ | Manual |
| 08 | _____ | _____ | _____ | Nikto |

| | | | | |
|---|---|---|---|---|
| 09 | _____ | _____ | _____ | Manual |
| 10 | _____ | _____ | _____ | Manual |

## TAREA 4 — Verificación manual con Nmap NSE y Nikto (40 min)

Los escáneres automáticos generan falsos positivos. Verificar manualmente los hallazgos críticos es una buena práctica que diferencia al auditor de quien simplemente ejecuta herramientas. La verificación manual también sirve para generar evidencias técnicas sólidas para el informe.

### 4.1 Verificación de vulnerabilidades críticas con Nmap NSE

Sustituye <IP_META> por la IP real de Metasploitable 2 en todos los comandos siguientes:

```
# CVE-2011-2523 — vsftpd 2.3.4 Backdoor
sudo nmap -p 21 --script ftp-vsftpd-backdoor <IP_META>

# CVE-2007-2447 — Samba username map script RCE
sudo nmap -p 445,139 --script smb-vuln-cve-2007-2447 <IP_META>

# CVE-2009-1185 — UnrealIRCd Backdoor
sudo nmap -p 6667 --script irc-unrealircd-backdoor <IP_META>

# Acceso FTP anónimo
sudo nmap -p 21 --script ftp-anon <IP_META>

# CVE-2012-1823 — PHP CGI Argument Injection
sudo nmap -p 80 --script http-php-version <IP_META>

# Vulnerabilidades web generales
sudo nmap -p 80,8180 --script http-vuln* <IP_META>
```

Registra los resultados en la siguiente tabla. La columna Estado indica si el hallazgo de OpenVAS ha sido CONFIRMADO, es FALSO POSITIVO o INCONCLUSO:

| CVE / Vulnerabilidad | Puerto | Resultado del script NSE | Estado |
|---|---|---|---|
| CVE-2011-2523 — vsftpd Backdoor | 21 | _____ | _____ |
| CVE-2007-2447 — Samba RCE | 445 | _____ | _____ |
| CVE-2009-1185 — IRC Backdoor | 6667 | _____ | _____ |
| FTP anónimo habilitado | 21 | _____ | _____ |
| Vulnerabilidades HTTP/PHP | 80 | _____ | _____ |

### 4.2 Análisis web con Nikto

Nikto complementa OpenVAS con un análisis específico de la capa HTTP. Proporciona evidencia adicional sobre configuraciones inseguras y versiones vulnerables del servidor web:

```
nikto -h <IP_META> -port 80 -output ~/lab02/nikto_puerto80.txt -Format txt

# Puerto 8180 — Apache Tomcat
nikto -h <IP_META> -port 8180 -output ~/lab02/nikto_tomcat8180.txt -Format txt
```

```
# Ver los hallazgos más importantes
grep -E 'CVE|OSVDB|Server|PHP|Apache|Tomcat' ~/lab02/nikto_puerto80.txt | head -20
```

## 4.3 Verificaciones manuales de servicios

Para los hallazgos más relevantes de servicios que no son HTTP, realiza las siguientes comprobaciones rápidas que generarán evidencia directa para el informe:

**FTP anónimo:**

```
ftp <IP_META>
# Usuario: anonymous   |   Contraseña: cualquier texto
# Ejecuta: ls -la    luego: quit
```

**Telnet en texto claro — captura simultánea con tcpdump:**

```
# Terminal 1: captura el tráfico del puerto 23
sudo tcpdump -i eth0 -w ~/lab02/evidencia_telnet.pcap port 23 and host <IP_META> &

# Terminal 2: conexión Telnet
telnet <IP_META>
# Usuario: msfadmin   |   Contraseña: msfadmin
# Ejecuta: whoami     luego: exit

# Detén la captura: kill %1   o Ctrl+C en Terminal 1
# Las credenciales serán visibles en el pcap con: strings
~/lab02/evidencia_telnet.pcap
```

**MySQL sin contraseña:**

```
mysql -h <IP_META> -u root --connect-timeout=5
# En el prompt MySQL: SHOW DATABASES;   luego: EXIT;
```

> ⚠ **AVISO:** Estas verificaciones solo demuestran la EXISTENCIA de la vulnerabilidad. El objetivo es generar evidencia técnica para el informe. No se ejecutan exploits completos ni se accede a datos. Documentar con capturas de pantalla cada resultado.

# TAREA 5 — Clasificación MAGERIT v3 y mapping ENS (30 min)

## 5.1 Catálogo de vulnerabilidades de referencia de Metasploitable 2

La siguiente tabla recoge las principales vulnerabilidades conocidas de Metasploitable 2. Marca las columnas OV (OpenVAS) y NSE (Nmap) según lo que hayas detectado en las tareas anteriores:

| # | Vulnerabilidad / CVE | Puerto | CVSS v3.1 | Detectada OV | Confirmada NSE |
|---|---|---|---|---|---|
| 01 | CVE-2011-2523 — vsftpd 2.3.4 Backdoor | 21 | 10.0 Crítico | ☐ Sí ☐ No | ☐ Sí ☐ No |
| 02 | CVE-2004-2687 — distcc RCE | 3632 | 9.3 Crítico | ☐ Sí ☐ No | ☐ Sí ☐ No |
| 03 | CVE-2007-2447 — Samba RCE | 445/139 | 9.3 Crítico | ☐ Sí ☐ No | ☐ Sí ☐ No |
| 04 | CVE-2003-0201 — Samba trans2open | 139 | 10.0 Crítico | ☐ Sí ☐ No | ☐ Sí ☐ No |
| 05 | CVE-2009-1185 — UnrealIRCd Backdoor | 6667 | 10.0 Crítico | ☐ Sí ☐ No | ☐ Sí ☐ No |
| 06 | CVE-2010-4478 — OpenSSH < 5.4 | 22 | 7.5 Alto | ☐ Sí ☐ No | ☐ Sí ☐ No |
| 07 | CWE-319 — Telnet sin cifrado | 23 | 7.4 Alto | ☐ Sí ☐ No | — |
| 08 | CVE-2009-3548 — Tomcat credenciales defecto | 8180 | 7.5 Alto | ☐ Sí ☐ No | ☐ Sí ☐ No |
| 09 | CVE-2012-1823 — PHP CGI RCE | 80 | 7.5 Alto | ☐ Sí ☐ No | ☐ Sí ☐ No |
| 10 | MySQL root sin contraseña | 3306 | 7.5 Alto | ☐ Sí ☐ No | — |
| 11 | PostgreSQL credenciales débiles | 5432 | 6.5 Medio | ☐ Sí ☐ No | — |
| 12 | NFS exportaciones sin restricción | 2049 | 6.5 Medio | ☐ Sí ☐ No | — |
| 13 | FTP acceso anónimo (CWE-425) | 21 | 5.0 Medio | ☐ Sí ☐ No | ☐ Sí ☐ No |
| 14 | Apache 2.2.x versión obsoleta | 80 | 5.0 Medio | ☐ Sí ☐ No | ☐ Sí ☐ No |
| 15 | BIND DNS versión obsoleta | 53 | 4.3 Medio | ☐ Sí ☐ No | — |

## 5.2 Mapping amenazas MAGERIT v3 y controles ENS

Relaciona los hallazgos principales con el catálogo de amenazas de MAGERIT v3 (Libro II) y los controles del ENS (Anexo II del RD 311/2022):

| Hallazgo | Amenaza MAGERIT v3 | Cód. | D | I | C | Control ENS |
|---|---|---|---|---|---|---|
| vsftpd Backdoor | Acceso no autorizado | [A.11] | — | ✓ | ✓ | op.pl.3 / mp.sw.2 |
| Samba RCE | Difusión de software dañino | [E.8] | ✓ | ✓ | ✓ | op.pl.3 / mp.com.1 |
| IRC Backdoor | Acceso no autorizado | [A.11] | ✓ | ✓ | ✓ | op.pl.3 / mp.sw.2 |
| Telnet sin cifrado | Interceptación (sniffing) | [A.5] | — | — | ✓ | mp.com.2 |
| MySQL sin contraseña | Abuso de privilegios | [A.6] | — | ✓ | ✓ | op.acc.5 |
| FTP anónimo | Acceso no autorizado | [A.11] | — | — | ✓ | op.acc.4 |
| Tomcat cred. defecto | Abuso de privilegios | [A.6] | ✓ | ✓ | ✓ | op.acc.5 / mp.sw.2 |
| NFS sin restricción | Acceso no autorizado | [A.11] | — | ✓ | ✓ | op.acc.4 |

Dimensiones MAGERIT: D = Disponibilidad · I = Integridad · C = Confidencialidad. Marca ✓ en cada dimensión afectada si la vulnerabilidad fuese explotada.

## TAREA 6 — Documentación de hallazgos (formato informe) (45 min)

Se incluyen tres hallazgos documentados como modelo. El alumno debe completar al menos dos adicionales con la misma estructura, a partir de sus propios resultados de OpenVAS.

| HALLAZGO H-01: Backdoor en vsftpd 2.3.4 — Shell remota sin autenticación | |
|---|---|
| **CVE / Referencia** | CVE-2011-2523 |
| **Servicio / Puerto** | FTP — vsftpd 2.3.4 (21/TCP) |
| **Severidad CVSS v3.1** | 10.0 — Crítico |
| **Descripción técnica** | El paquete vsftpd 2.3.4 contiene un backdoor introducido maliciosamente en el código fuente del proyecto. Cuando un atacante inicia sesión FTP con un nombre de usuario que contiene la cadena ':)' (smiley), vsftpd abre una shell de comandos en el puerto 6200/TCP accesible sin ninguna autenticación adicional. El vector CVSS es AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H. |
| **Evidencia requerida** | Captura de pantalla del resultado del plugin OpenVAS. Salida del script NSE: nmap -p 21 --script ftp-vsftpd-backdoor <IP_META>. La salida debe mostrar: '21/tcp open ftp VULNERABLE: vsFTPd version 2.3.4 backdoor'. |
| **Impacto potencial** | Ejecución remota de código con los privilegios del proceso vsftpd. Sin necesidad de autenticación y sin interacción del usuario. Impacto total en Confidencialidad, Integridad y Disponibilidad del sistema. Permite comprometer completamente el servidor. |
| **Recomendación** | Desinstalar vsftpd 2.3.4 inmediatamente: apt remove vsftpd. Instalar una versión no afectada desde repositorios oficiales (≥ 3.0.x). Verificar integridad del nuevo paquete con sha256sum antes de instalar. Si el servicio FTP es necesario, evaluar la migración a SFTP. |
| **Referencia normativa** | ENS: op.pl.3 (Gestión de la configuración) — plazo de corrección: 7 días para vulnerabilidades críticas. ISO 27001:2022 A.8.8 (Gestión de vulnerabilidades). MAGERIT v3: Amenaza [A.11] Acceso no autorizado, dimensiones C e I. |

| HALLAZGO H-02: Samba 3.0.x — Ejecución remota de código via username map script | |
|---|---|
| **CVE / Referencia** | CVE-2007-2447 |
| **Servicio / Puerto** | SMB — Samba 3.0.20 (445/TCP) |
| **Severidad CVSS v3.1** | 9.3 — Crítico |
| **Descripción técnica** | Samba versiones 3.0.0 a 3.0.25rc3 permite la ejecución remota de código cuando la opción 'username map script' está configurada en smb.conf. El atacante puede inyectar metacaracteres de shell en el campo de nombre de usuario durante la autenticación. No requiere privilegios previos. Vector CVSS: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H. |
| **Evidencia requerida** | Captura del plugin OpenVAS con el detalle de la vulnerabilidad. Salida del script: nmap -p 445 --script smb-vuln-cve-2007-2447 <IP_META>. Captura del fichero /etc/samba/smb.conf mostrando la opción username map script habilitada. |
| **Impacto potencial** | Ejecución remota de código con los privilegios del proceso smbd (root en Metasploitable 2). Control total del sistema operativo. Afecta las tres dimensiones: Confidencialidad, Integridad y Disponibilidad. |
| **Recomendación** | Actualizar Samba a la versión más reciente disponible en el repositorio oficial. Eliminar o comentar la línea 'username map script' en smb.conf si no es estrictamente necesaria. Implementar reglas de firewall para restringir el acceso al puerto 445 a hosts autorizados. Evaluar si SMBv1 es necesario; deshabilitar si no lo es. |

| | |
|---|---|
| **Referencia normativa** | ENS: op.pl.3 (corrección ≤ 7 días), mp.com.1 (Protección de las comunicaciones). ISO 27001:2022 A.8.8, A.8.20 (Seguridad de redes). MAGERIT v3: Amenaza [E.8] Difusión de software dañino, dimensiones C, I y D. |

| **HALLAZGO H-03: Telnet — Transmisión de credenciales en texto claro** | |
|---|---|
| **CVE / Referencia** | CWE-319 — Cleartext Transmission of Sensitive Information |
| **Servicio / Puerto** | Telnet (23/TCP) |
| **Severidad CVSS v3.1** | 7.4 — Alto |
| **Descripción técnica** | El servicio Telnet (puerto 23) transmite todo el tráfico, incluyendo credenciales de autenticación, sin ningún tipo de cifrado. Cualquier agente con acceso a la red local puede capturar el tráfico mediante técnicas de sniffing pasivo o ARP spoofing y extraer nombres de usuario y contraseñas en texto claro. |
| **Evidencia requerida** | Captura de pantalla de tcpdump o Wireshark mostrando las credenciales en texto claro en el flujo TCP del puerto 23. Guardar el fichero: ~/lab02/evidencia_telnet.pcap. En el terminal: strings ~/lab02/evidencia_telnet.pcap \| grep -A2 -B2 'msfadmin'. |
| **Impacto potencial** | Exposición de credenciales de autenticación a cualquier agente en la red. Si las credenciales de Telnet se reutilizan en otros servicios (SSH, bases de datos), el compromiso es total. Vulneración de la dimensión de Confidencialidad. Art. 5.1.f RGPD: principio de confidencialidad e integridad. |
| **Recomendación** | Deshabilitar Telnet: sudo systemctl disable telnet && sudo systemctl stop telnet. Migrar toda gestión remota a SSH (cifrado). Revisar si existen otros servicios heredados en texto claro (rlogin, rsh, rexec, FTP) y deshabilitarlos. Implementar política de prohibición de protocolos sin cifrado. |
| **Referencia normativa** | ENS: mp.com.2 (Cifrado de las comunicaciones) — nivel MEDIO exige cifrado de comunicaciones externas e internas. ISO 27001:2022 A.8.24 (Uso de criptografía). RGPD art. 5.1.f (integridad y confidencialidad). MAGERIT v3: Amenaza [A.5] Suplantación de identidad, dimensión C. |

Hallazgos H-04 y H-05 — A completar por el alumno con sus propios resultados de OpenVAS:

| Campo del hallazgo | H-04 (completar) | H-05 (completar) |
|---|---|---|
| CVE / Referencia | _____ | _____ |
| Servicio / Puerto | _____ | _____ |
| Severidad CVSS v3.1 | _____ | _____ |
| Descripción técnica | _____ | _____ |
| Evidencia obtenida | _____ | _____ |
| Impacto potencial | _____ | _____ |
| Recomendación | _____ | _____ |
| Referencia normativa | _____ | _____ |

# 5. ENTREGABLE — INFORME TÉCNICO DE VULNERABILIDADES

## 5.1 Estructura del informe

- 1. Portada: datos del alumno, fecha, sistema auditado, entorno controlado.
- 2. Declaración de alcance: herramientas, tipos de escaneo, IP del objetivo, autorización de laboratorio.
- 3. Resumen ejecutivo: total de vulnerabilidades por severidad, top 3 hallazgos críticos, recomendación principal. Máximo 1 página, sin tecnicismos.
- 4. Metodología: descripción del proceso (OpenVAS sin/con credenciales, verificación NSE, Nikto), referencia a MAGERIT v3 e ISO 27001:2022 A.8.8.
- 5. Tabla resumen de vulnerabilidades: todos los hallazgos ordenados por CVSS v3.1 descendente.
- 6. Fichas de hallazgos: mínimo 5 hallazgos con la estructura de la Tarea 6.
- 7. Plan de remediación priorizado (ver tabla 5.2).
- 8. Conclusiones: valoración del nivel de seguridad según ENS, recomendación de categoría de riesgo global.
- 9. Anexos: exportaciones OpenVAS (XML y PDF), salidas Nikto, fichero PCAP de Telnet, capturas de pantalla numeradas.

## 5.2 Plan de remediación priorizado

| Prioridad | Hallazgo | CVSS | Acción | Plazo ENS | Responsable |
|---|---|---|---|---|---|
| 1 — CRÍTICA | CVE-2011-2523 vsftpd | 10.0 | Desinstalar vsftpd 2.3.4. Instalar ≥ 3.0.x | ≤ 7 días | Administ. sistemas |
| 1 — CRÍTICA | CVE-2007-2447 Samba | 9.3 | Actualizar Samba + deshabilitar username map | ≤ 7 días | Administ. sistemas |
| 1 — CRÍTICA | CVE-2009-1185 IRC | 10.0 | Desinstalar UnrealIRCd. Evaluar necesidad. | ≤ 7 días | Administ. sistemas |
| 2 — ALTA | Telnet sin cifrado | 7.4 | Deshabilitar Telnet. Migrar a SSH. | ≤ 30 días | Administ. sistemas |
| 2 — ALTA | MySQL sin contraseña | 7.5 | Establecer contraseña root. Restringir acceso. | ≤ 30 días | Administ. base datos |
| 3 — MEDIA | FTP anónimo | 5.0 | Deshabilitar acceso FTP anónimo. | ≤ 90 días | Administ. sistemas |
| 3 — MEDIA | NFS sin restricción | 6.5 | Configurar exports con restricción por host. | ≤ 90 días | Administ. sistemas |

## 5.3 Ficheros a entregar

```
mkdir -p ~/lab02/entrega && cp ~/lab02/*.* ~/lab02/entrega/
zip LAB02_[apellido]_[nombre].zip ~/lab02/entrega/
```

| Fichero | Contenido |
|---|---|
| lab02_openvas_sin_cred.xml | Export XML del escaneo OpenVAS sin credenciales |
| lab02_openvas_sin_cred.pdf | Informe PDF del escaneo sin credenciales |
| lab02_openvas_con_cred.xml | Export XML del escaneo OpenVAS con credenciales SSH |
| lab02_openvas_con_cred.pdf | Informe PDF del escaneo con credenciales |
| nikto_puerto80.txt | Análisis Nikto del servidor web (puerto 80) |

| | |
|---|---|
| nikto_tomcat8180.txt | Análisis Nikto de Apache Tomcat (puerto 8180) |
| evidencia_telnet.pcap | Captura tcpdump de sesión Telnet con credenciales en claro |
| informe_lab02.pdf | Informe técnico de vulnerabilidades completo |

# 6. PREGUNTAS DE REFLEXIÓN

- El escaneo autenticado detecta vulnerabilidades adicionales respecto al no autenticado. Explica por qué esto es relevante desde el punto de vista de la gestión de riesgos MAGERIT v3: ¿cómo afecta al cálculo de probabilidad de una amenaza de tipo [A.11] Acceso no autorizado?
- OpenVAS clasifica las vulnerabilidades con CVSS v3.1. Elige uno de los hallazgos críticos que hayas encontrado, desglosa su vector CVSS (AV, AC, PR, UI, S, C, I, A) y explica cada componente. ¿Qué cambiaría en la puntuación si el servicio no fuera accesible desde Internet?
- El artículo 33 del RGPD exige notificar a la AEPD las brechas de seguridad en un máximo de 72 horas. Durante el análisis has encontrado que MySQL está accesible sin contraseña desde la red. Si en ese servidor hubiera datos de carácter personal: ¿sería esto una brecha notificable? ¿Qué pasos debe seguir el DPO?
- El ENS (RD 311/2022) establece plazos de corrección según la severidad. Con los hallazgos que has obtenido, ¿en qué categoría ENS (BÁSICA / MEDIA / ALTA) clasificarías el sistema Metasploitable 2? Justifica usando los criterios del Anexo I del RD 311/2022.
- Nikto ha encontrado probablemente más hallazgos en el servidor web que OpenVAS, o viceversa. ¿Por qué dos herramientas diferentes pueden dar resultados distintos sobre el mismo objetivo? ¿Cómo debería gestionar el auditor esta discrepancia en el informe final?

# 7. RÚBRICA DE EVALUACIÓN

| Criterio de evaluación | Insuficiente (0–4) | Suficiente (5–7) | Excelente (8–10) |
|---|---|---|---|
| OpenVAS — Uso y configuración (25%) | No genera escaneos o resultados vacíos | Escaneos básicos correctamente ejecutados | Políticas sin cred. y autenticada, configuración avanzada justificada |
| Clasificación CVSS v3.1 (25%) | Severidades incorrectas o sin justificación | Clasifica correctamente la mayoría de hallazgos | Clasificación precisa con vector CVSS justificado para cada hallazgo |
| Informe técnico (30%) | Sin estructura o incompleto | Estructura correcta con hallazgos principales | Informe profesional con evidencias, impacto y recomendaciones normativas |
| Marco normativo (20%) | No referencia normativa aplicable | Menciona ENS o MAGERIT en algún hallazgo | Cada hallazgo vinculado a ENS, MAGERIT v3 e ISO 27001:2022 A.8.8 |

Nota final: media ponderada de los cuatro criterios. Nota mínima de 5 en cada criterio para superar el laboratorio.

ℹ Los ficheros XML exportados de OpenVAS se usarán en el LAB-07 (Análisis de riesgos MAGERIT completo) como input del inventario de vulnerabilidades. Consérvalo.

# 8. REFERENCIAS

## Normativa


- Real Decreto 311/2022, de 3 de mayo — Esquema Nacional de Seguridad. Medida op.pl.3. BOE núm. 106.
- ISO/IEC 27001:2022. Control A.8.8: Management of technical vulnerabilities.
- ISO/IEC 27002:2022. Sección 8.8 — Orientación para la gestión de vulnerabilidades técnicas.
- RGPD — Reglamento (UE) 2016/679. Art. 32 (seguridad del tratamiento) y art. 33 (notificación de brechas).
- LOPDGDD — Ley Orgánica 3/2018. Artículo 37 (Delegado de Protección de Datos).
- CCN-CERT. MAGERIT v3 — Libro I (Método) y Libro II (Catálogo de Elementos). MINHAP, 2012.
- CCN-STIC 817 — Gestión de ciberincidentes en el ENS. Centro Criptológico Nacional, 2023.


## Técnicas


- Greenbone Networks. Greenbone Community Edition — Documentation. https://greenbone.github.io/docs/
- NIST. National Vulnerability Database (NVD). https://nvd.nist.gov/
- FIRST.org. CVSS v3.1 Specification Document. https://www.first.org/cvss/specification-document
- MITRE. CVE — Common Vulnerabilities and Exposures. https://cve.mitre.org/
- MITRE. CWE — Common Weakness Enumeration. https://cwe.mitre.org/
- Kali Linux. OpenVAS setup on Kali. https://www.kali.org/tools/gvm/